

|
| S4 | Begin working on the ~"bug::vulnerability" and ~"FedRAMP::Vulnerability" security issue at least 2 Milestones prior to the due date |
| S1,S2 or S3 that is blocked | The team that owns the blocking issue, should disrupt their current milestone and work on the blocking issue right away |

Reproducibility on ~security Issues

The issue description should have a How to reproduce section to ensure clear replication details are in description. Add additional details, as needed:

- Environment used:
 - Docker Omnibus version x.y.z
 - gitlab.com
 - staging.gitlab.com
- Conditions used such as projects, users, enabled features or files used
- A step by step plan to reproduce the issue
- The url or even better the curl command that triggers the issue

Non-vulnerability ~security issues

Issues labeled with the security but without ~type::bug + ~bug::vulnerability labels are not considered vulnerabilities, but rather security enhancements, defense-in-depth mechanisms, or other security-adjacent bugs. For example, issues labeled ~"type::feature" or ~"type::maintenance". This means the security team does not set the ~severity and ~priority labels or follow the vulnerability triage process as these issues will be triaged by product or other appropriate team owning the component.

Implementation of security feature issues should be done publicly in line with our Transparency value, i.e. not following the security developer workflow.

On the contrary, note that issues with the security, ~type::bug, and severity::4 labels are considered Low severity vulnerabilities and will be handled according to the standard vulnerability triage process.

~"security request"

The security team may also apply ~internal customer and ~security request to issue as an indication that the feature is being requested by the security team to meet additional customer requirements, compliance or operational needs in support of GitLab.com.

~"securitybot::ignore"

Some ~security issues are neither vulnerabilities nor security enhancements and yet are labeled ~security. An example of this would be a non-security ~"type::bug" in the login mechanism. Such an issue will be labeled ~security because it is security-sensitive but it isn't a vulnerability and it isn't a ~"type::feature" either. In those cases the ~"securitybot::ignore" label is applied so that the bot doesn't trigger the normal vulnerability workflow and notifications as those issues aren't subject to the "time to remediation" requirements

mentioned above.

Transferring from Security to Engineering

The security engineer must:

- Add group label (~group::editor, ~group::package, etc.)
- Add stage label
- Any additional labels, such as ~merge request.
- Mention the product manager for scheduling, such as @pm for scheduling.
- The engineering team lead should be @ mentioned and followed up with when necessary as noted below for different severity levels.

The product manager will assign a Milestone that has been assigned a due date to communicate when work will be assigned to engineers. The Due date field, severity label, and priority label on the issue should not be changed by PMs, as these labels are intended to provide accurate metrics on ~security issues, and are assigned by the security team. Any blockers, technical or organizational, that prevents ~security issues from being addressed as our top priority should be escalated up the appropriate management chains.

Note that issues are not scheduled for a particular release unless the team leads add them to a release milestone and they are assigned to a developer.

Issues with an severity::1 or severity::2 rating should be immediately brought to the attention of the relevant engineering team leads and product managers by tagging them in the issue and/or escalating via chat and email if they are unresponsive.

Issues with an severity::1 rating have priority over all other issues and should be considered for a critical security release.

Issues with an severity::2 rating should be scheduled for the next scheduled security release, which may be days or weeks ahead depending on severity and other issues that are waiting for patches. An severity::2 rating is not a guarantee that a patch will be ready prior to the next security release, but that should be the goal.

Issues with an severity::3 rating have a lower sense of urgency and are assigned a target of the next minor version. If a low-risk or low-impact vulnerability is reported that would normally be rated severity::3 but the reporter has provided a 30 day time window (or less) for disclosure the issue may be escalated to ensure that it is patched before disclosure.

Security issue becoming irrelevant due to unrelated code changes

It is possible that a ~security issue becomes irrelevant after it was initially triaged, but before a patch was implemented. For example, the vulnerable functionality was removed or significantly changed resulting in the vulnerability not being present anymore.

If an engineer notices that an issue has become irrelevant, they should @-mention the person that triaged the issue to confirm that the vulnerability is not present anymore. **Note** that it might still be necessary to backport a patch to previous releases according to our maintenance policy.

In case no backports are necessary, the issue can be closed.

Reducing the number of backports

With the approval of an Application Security Engineer a security issue may be fixed on the current stable release only, with no backports. Follow the GitLab Maintenance Policy and apply the ~reduced backports label to the issue.

SECTION: security/external-security-communications-procedure.md

Purpose

This procedure is intended to identify the Security Organization's ownership and approval on categories/topics of external communication.

Scope

This procedure applies to external communications associated with the Security organization.

Roles & Responsibilities

Security Owns and Approves (external communications):

- 1. Customer communications on security events or identified vulnerabilities
- 1. Security releases, regular and critical
- 1. All bug bounty program updates and communication
- 1. Customer response communications

Security shared communications efforts: Corporate Marketing reviews and approves:

- 1. Blog posts published through GitLab blog (vs Unfiltered Blog): corporate blog team conducts final, editorial review on security-approved blogs
- 1. Incident response communications: breach, customer compromise, data loss: these are usually multi-pronged responses, requiring input, review and approval from multiple corporate functions: legal, product, marketing, support, etc.
- 1. External notifications associated with Security certifications and initiatives such as SOC 2 and FedRAMP

Security Consult - Corporate Marketing Owned

- 1. Interviews / media engagement
- 1. Contributed articles

Procedure

There are typically three communications areas that might warrant a Security Division response:

- New Feature. Most likely the Security Division is already involved in the process, however if specific wording is needed, ensure the Security Division is involved. It should be noted this does NOT require a Security Communications issue.
- Incident. This involves a breach, accidental disclosure of sensitive information, and so on. It typically will not involve a security flaw but more of a failure of configuration, permissions, and other similar scenario.
- Vulnerability. A security issue, such as one reported internally or via our HackerOne program, involving GitLab code or configurations.

The normal process involves making information public after an incident is contained and/or a security flaw has been fixed.

NOTE: It is quite possible that an incident will not involve public notification, due to potential confidentiality surrounding the incident. If you are unsure, follow the GitLab SAFE Framework. However if the Security Division feels that the GitLab and security communities at large could benefit, there might be a release of information such as configuration recommendations or new techniques to help secure information. This type of disclosure does not necessarily mandate a specific timeframe or requirements, but still should be performed in a timely manner.

Regardless, any release of external communications, be it a specific issue or incident, will start with a Security Communications issue (internal link). When creating this issue, select the most appropriate template, and if you have any questions bring them up in the GitLab internal Slack channel security.

There are typically three communications areas that might warrant a Security Department response:

- New Feature. Most likely the Security Department is already involved in the process, however if specific wording is needed, ensure the Security Department is involved. It should be noted this does NOT require a Security Communications issue.
- Incident. This involves a breach, accidental disclosure of sensitive information, and so on. It typically will not involve a security flaw but more of a failure of configuration, permissions, and other similar scenario. If the incident requires a public response, fill out a Security Communications issue.
- Vulnerability. A security issue, such as one reported internally or via our HackerOne program, involving GitLab code or configurations. Public communication is handled by the Security Release Process. During that process, the responsible AppSec engineer will need to open a Security Communications issue to send communications about the security release. This is the main area where most security-related communications are generated.

Remember that it is not unusual for security-related patches to be in the regular GitLab release every month as the GitLab codebase is updated continuously, but vulnerabilities are addressed in the monthly security release happens roughly one week after the regular GitLab release.

Exceptions

Exceptions to this procedure will be tracked as per the Information Security Policy Exception Management Process.

References

Security incident communications plan

SECTION: security/gearing-ratios.md

Bug bounties

The gearing ratio for bug bounty expenditure is as follows:

- The cost of a compromise is estimated at 1% of company worth
- Bug Bounty budget is determined as 10% of a compromise
- Bug Bounty top reward is determined as 1% of budget

An illustration:

GitLab is worth 3.5 billion and a significant compromise can cost GitLab \$35 million.
10% ratio = \$3.5 million budget. Likewise, 1% of budget = \$35,000 top reward

Approximate monthly budget should be set at total budget divided by 12. It should be understood that our bug bounty payouts are largely unpredictable and fluctuate based on the following:

- Number and severity of bugs produced by GitLab and pushed to production
- Participation of research community
- Reward ranges

This gearing ratio is owned by the Product Security Sub-department. The cost of a compromise should be re-evaluated at least annually based on the average market cap of GTLB over the previous 6 months.

Security Incident Response Team (SIRT) size

SIRT is the sole carrier of the Security On-Call (SEOC) rotation, which ensures that there's a page-able Security Engineer 24/7/365. The baseline and gearing ratio for the size of the SIRT have been agreed on as outlined below:

- Baseline:
 - 12 team members to cover 3 timezone in a 8 hour, follow-the-sun rotation:
 - 4 team members in JAPAC
 - 4 team members in EMEA
 - 4 team members in AMER
- Gearing ratio that triggers a review of team size:
 - If number of pages to SEOC per month exceeds +50% of monthly average of the last 12 months for 3 consecutive months
 - If number of pages to SEOC per year exceeds +100% of previous year

- If number of total team members increases by +20% compared to previous year

This gearing ratio is owned by the Security Operations Sub-department.

SECTION: security/gitlab_security_resource_center.md

Commonly requested resources

Contacting GitLab for reporting security issues

- Reporting Abuse
- Coordinated Disclosure Process
- HackerOne Reporting Process

GitLab's Customer Assurance Package (CAP)

Our Customer Assurance Package contains documents such as our SOC2 report, ISO 27001 certificate, penetration test executive summary, and pre-filled CAIQ and SIG questionnaires, among many other documents. Please see our CAP page to request the package.

GitLab's Trust Center

Our Trust Center outlines the various compliance and assurance credentials that GitLab maintains. This page also contains links to important security, legal & privacy, and availability resources, such as an overview of our security practices, our Environmental, Social, and Governance strategy, and our production architecture.

Frequently asked questions

The following links contain frequently asked security, legal & privacy, and availability questions.

- Security FAQs
- Legal & Privacy FAQs
- Availability FAQs

Control topics

Table of contents

| Acceptable use | Access management | Business continuity | Cryptography | Data classification
| Disaster recovery | Endpoint management | Hardening | Incident response and communication |
Independent assurance
| Logging and monitoring | Network security | Privacy | Security awareness | Third party risk
management
| Threat modeling | Vulnerability management |

Acceptable use

- Internal acceptable use policy
- GitLab's terms of use

Access management

- Access Management Policy
- Access Review Procedure
- Access Request process

Business continuity

- Business Continuity Plan
- Business Impact Analysis
- Information System Contingency Plan

Cryptography

- GitLab cryptography standard
- Encryption policy

Data classification

- Data classification standard
- Record retention policy
- Records retention and disposal standard

Disaster recovery

- Disaster recovery plan
- Database disaster recovery
- Database overview

Endpoint management

- Endpoint management at GitLab
 - Jamf
 - EDR
- Use Gitleaks as a pre-commit git hook on laptops

GitLab.com hardening techniques

- GitLab projects baseline requirements
- GitLab security requirements for deployment and development
- How to harden your self-managed GitLab instance
- The ultimate guide to securing your code on GitLab.com

Incident response and communication

- Security incident communications plan procedure
- Security incident response guide

Independent assurance

- Independent Security Assurance

Logging and monitoring

- Monitoring of gitlab.com
- Log management for gitlab.com
- Logging and monitoring architecture
- GitLab audit logging policy
- Log and audit requests process
- Infrastructure production runbooks

Network security

- Network security management procedure
- GitLab security requirements for deployment and development

Privacy

- GitLab Privacy Statement
- Team Member Privacy Notice
- U.S. State Privacy Rights and Disclosures
- Account deletion and data access requests workflow

Security awareness

- Security training
- Security awareness training program
- Security awareness training procedure
- Phishing program

Third party risk management

- Security third party risk management

Threat modeling

- Threat modeling at GitLab
- Threat modeling How To Guide
- Application security threat modeling process

Vulnerability management

- Vulnerability management standard
- Application vulnerability management procedure
- Infrastructure vulnerability management procedure

SECTION: security/gitleaks.md

gitleaks on your laptop

If you ended up on this handbook page it's probably because you have been pointed here during a git commit by our gitleaks installation on your local machine. The tool gitleaks is being used on GitLab endpoints to prevent a common security issue, namely accidental commits of secrets like Personal Access Token or other credentials to public repositories. It is important that all repositories are covered as a leaked access token in one repository can impact all repositories and projects to which your account has access.

What did just happen?

gitleaks detected that you tried to commit something which looks like a secret to a git repository. The output should look something like this:

text

```
.  
..  
. .  
. .  
. .  
· gitleaks
```

```
{  
  "Description": "GitLab Personal Access Token",  
  "StartLine": 7,  
  "EndLine": 7,  
  "StartColumn": 2,  
  "EndColumn": 27,  
  "Match": "REDACTED",  
  "Secret": "REDACT",  
  "File": "testfile",  
  "Commit": "",  
  "Entropy": 0,  
  "Author": "",  
  "Email": "",  
  "Date": "0001-01-01T00:00:00Z",  
  "Message": "",  
  "Tags": [],  
  "RuleID": "gitlab-pat"  
}
```

9:27AM WRN leaks found: 1

9:27AM INF scan duration: 51.840347ms

The Description field will tell you what kind of secret gitleaks detected, you can verify this by inspecting the file listed in the File field at StartLine.

What should I do now?

It's never a good practice to store plain secrets within code repositories. You should remove the offending secrets from the files you wanted to commit and find a safe place for them. If you're unsure what to do, feel free to reach out in the security Slack channel.

If you are absolutely sure the secret detected by gitleaks is a false positive and you want to commit anyhow set the environment variable IWANTGITLEAKSSKIP once for the commit to avoid the gitleaks scan for this commit. This would look like so on the command line:

```
sh
IWANTGITLEAKSSKIP=1 git commit -m 'Commit a dummy secret'
```

Please do not set this variable permanently as it would subvert the protection mechanism. Since version 8.5.0 there's also a feature in gitleaks to ignore dummy secrets by having gitleaks:allow in the same line with the secret.

SECTION: security/individual-development-plan.md

From FY24-Q2 - Individual Growth Plan

Since the launch of the company wide Individual Growth Plan in Workday per FY24-Q2 we recommend Security team members to leverage that tool in Workday to collaborate with their manager on their career path and growth opportunities. Team members can read all about that progress in this guide. We have deprecated the The Individual Development Plan (IDP) template

Till FY24-Q2 - Individual Development Plan

The Individual Development Plan (IDP) template was used by Security team members till FY24-Q1 to help collaborate on a team member's career path and growth opportunities. The template was designed to document a team member's personal choices and the direction they want to take their career while allowing their manager to provide guidance and assist with career growth. The use of this template is entirely voluntary and optional. In fact, the template format and process used are also both flexible and adaptable to each manager and team member. Feel free to adapt the template in manners that meet the needs of the manager and team member.

Process

The process a manager and team member follow is entirely up to them. However, it is strongly encouraged to use team member 1:1 meetings to discuss career opportunities and growth in conjunction with the performance review process. This template and any process that is followed, is not intended to replace the Engineering Performance Review process. Lastly, while managers should be engaging their team members and actively involved in their direct report's growth, it is the responsibility of the team member to take the initiative to start this

process with their manager and subsequently follow through with actions assigned to them. A team member should drive this process and their own personal development at a pace they are comfortable with. IDPs should be shared with the team member's direct manager and others only as chosen by the team member.

Professional goals and aspirations

This section of the template should be solely filled out by the team member and used to clearly communicate both short term and long term career goals. These goals can be as small as obtaining a certification and as large as working to take on the role of CEO some day. While these goals drive the entire conversation from the start, a team member should not feel pressured to document a long term goal but at a minimum, a short term goal is required.

Strengths and talents

The team member and their manager should agree upon what is documented in this section. The strengths and talents of the team member should help determine what aspects of their current skill set can be leveraged to foster continued growth and show sustained performance of responsibilities for a role the team member may be interested in obtaining.

Development opportunities

Possibly the most important section of the template, clearly establishing the skills, knowledge, and experience that will be required of a team member to achieve their goals and aspirations is critical to the success of a development plan. Agreement between the manager and team member on the documented development opportunities is equally important. These should be discussed in detail to ensure both team members have a clear understanding of the development opportunities.

Action plan

The action plan must clearly describe the steps to be taken, potentially in a specific order, and what the specific action plan step will accomplish. These steps should align closely with the development opportunities documented. Additionally, action plans should be specific and achievable. Though the action plan items should be tracked with agreed to dates, missing these dates must not reflect negatively on the team member. The goal of the IDP is to provide the basic means for a manager to assist with the growth of a team member and the team member to clearly understand that which is required to grow their career in the direction they have defined. It is not intended to be a measure of performance.

Questions

Feel free to contact the Security Team in our Slack Channel.

SECTION: security/information-system-contingency-plan-iscp.md

Purpose

An ISCP provides established procedures for the assessment and recovery of a system following a system disruption. The ISCP provides key information needed for system recovery, including roles and responsibilities, inventory information, assessment procedures, detailed recovery procedures, and testing of a system. An ISCP will be created for GitLab.com and Tier 1 systems, working in conjunction with the Business Continuity Plan (BCP) and Disaster Recovery Plan (DRP).

Difference between ISCP and DRP

The ISCP differs from a DRP primarily in that the information system contingency plan procedures are developed for recovery of the system regardless of site or location. An ISCP can be activated at the system's current location or at an alternate site. In contrast, a DRP is primarily a site-specific plan developed with procedures to move operations of one or more information systems from a damaged or uninhabitable location to a temporary alternate location. Once the DRP has successfully transferred an information system site to an alternate site, each affected system would then use its respective ISCP to restore, recover, and test systems, and put them into operation. (ref: NIST 800-34)

Information System Contingency Policy Statement

GitLab will develop contingency plans for GitLab.com and Tier 1 systems to meet the needs of critical system operations in the event of a disruption. The procedures for execution of such a capability shall be documented in a formal contingency plan by the Information Systems Contingency Plan (ISCP) Coordinator and must be reviewed annually and updated as necessary by the ISCP Coordinator. The plan must account for the FIPS 199 security categorization (low, moderate, high) and comply with the appropriate security controls. The plan must assign specific responsibilities to designated staff or positions to facilitate the recovery and/or continuity of essential system functions. Resources necessary to ensure viability of the procedures must be acquired and maintained. Personnel responsible for target systems must be trained to execute contingency procedures. The plan recovery capabilities and personnel shall be tested annually to identify weaknesses of the capability.

Roles & Responsibilities

Role	Responsibility
------	----------------

-----	-----
-------	-------

Security Compliance	The Security Compliance team will be the Information Systems Contingency Plan (ISCP) Coordinator; At least annually review the ISCP; Provide assistance in the coordination and facilitation of ISCP tests; Acts as point of contact for any external audits.
---------------------	---

Application Security	Manage application vulnerability program; maintain application security tools; identify security risks.
----------------------	---

Infrastructure	Responsible for infrastructure management and support.
----------------	--

Infrastructure Security	Manage infrastructure vulnerability program; maintain infrastructure security tools; identify security risks.
-------------------------	---

Exceptions

There are no exceptions to the ISCP.

References

- NIST 800-34
- BCP
- Disaster Recovery Plan (DRP)
- Database DR

SECTION: security/internship.md

Overview

The Security internship is the result of The Engineering Internship Pilot Program that started at the end of 2019. The ultimate goal of this program is to transform an entry-level candidate into an Individual Contributor who could meet the requirements for a Security Engineer.

OKRs for the Internship

Objective: Provide Exposure to Different Functional Areas of Security

- Key Result: Intern completes at least one week with each functional team in security.
- Key Result: Intern completes at least one key result in each functional area. (Outlined Below)

Objective: Contribute to security of GitLab the product or GitLab the company

- Key Result: Intern completes a technical project that enhances the security of the GitLab product, or the security posture of the company.

Objective: Effective Communication of Security Ideas

- Key Result: Intern publishes a blog post on their internship experience or a security-related project on which they worked.

Objective: Expand the Intern's Network

- Key Result: Intern completes 10 coffee chats with GitLab Team Members outside of the Internship Program

Functional Area KRs

Area: Application Security & Security Research - Weeks of May 18th & 25th

- Key Result: Intern participates in the triage of 5 Hackerone reports
- Key Result: Intern participates in the response to 5 appsec pings

Area: Security Operations - Weeks of June 1st and 8th

- Key Result: Intern participates in the creation of 5 detection rules
- Key Result: Intern shadows 1 on-call or other security incident

Area:Trust & Safetys - Week of June 15th

- Key Result: Improve the detection of potential CI Abuse

Area:Security Assurance - Week of June 22nd

- Key Result: Complete a testing worksheet for 1 GCF control against 1 system/profile
- Key Result: Shadow on 1 sales call

Area:Security Automation - Week of June 29th

- Key Result: TBD

Area:Red Team - Week of July 6th

- Key Result: Determine the best approach to implement machine learning into GitRob's secret scanning.
- Key Result: Build PoC to demonstrate capabilities.

Roles

- Security Manager - Manager
- Senior Security Engineer(s) - Mentor(s)
- Security Intern

Responsibilities

Manager Responsibilities

Prior to the Start of the Internship:

- Engineering Manager and Mentor Internship Kick Off Meeting

During the first week:

- Schedule Weekly Meeting (no need to record these meetings)
- Walk through various team processes
- Work with intern to define their growth goals
- Create a rotation of functional teams and coordinate with team managers

Daily:

- Review / Respond to the Intern Daily Check In
- Serve as resource to the Intern for answering technical questions

Weekly

- Weekly 1-1:
 - Agenda:
 - Discuss Outstanding Questions

- Review Status of current rotation
- Review Status of growth goals and OKRs
- Ensure that intern has pair work time scheduled for each week

As needed:

- Create a backlog of small issues and assign to the Mentor, Engineering Manager and the Intern
- Identify best topics to pair work with the intern

Mentor Responsibilities

The Intern will have a Primary Mentor, however as the intern rotates throughout the teams, a engineer for each time should be designated as the mentor for that rotation.

Prior to the Start of the Internship:

- Engineering Manager and Mentor Internship Kick Off Meeting

Daily:

- Serve as resource to the Intern for answering technical questions

During the first week:

- Schedule Weekly Meeting (no need to record these)
- Walk through the security team processes with the intern

Weekly

- Participate in at least one pair work session
- Weekly 1-1:
 - Agenda:
 - Discuss Outstanding Questions
 - Review Status of current rotation
 - Review Status of current project

As needed:

- Identify best topics to pair work with the intern.

Intern Responsibilities

During the first week:

- Follow the Internship Day to Day Activities
- Become familiar with the security section of the handbook
- Work with the manager to define goals for the internship

Weekly:

- Pre Populate the 1:1 agenda prior to the meeting
- Prioritize your work for the week and add to Google Calendar
- Participate in team meetings and activities
- Attend Coffee Chats with various GitLab Team Members

Daily:

- Perform a Daily Check In through Slack to the EditorInternSlack private channel
 - What did you do yesterday?
 - What do you plan to do today?
 - Is anything blocking your work?
- Complete pair work sessions and assigned tasks in team rotations

SECTION: security/isms.md

Purpose

GitLab has adopted the ISO/IEC 27001:2022 standard for our information security management system (ISMS) and ISO/IEC 42001:2023 for our artificial intelligence management system (AIMS) to provide GitLab team members, customers and community members with a high level of assurance on the robustness of our information security policies, standards and procedures, and the strength of our control environment. The purpose of this document is to define the boundaries and objectives of GitLab's information security and artificial intelligence management system.

Scope

The scope of GitLab's ISMS is limited to the production resources that directly support GitLab SaaS subscriptions: GitLab.com and GitLab Dedicated.

The scope of GitLab's AIMS covers GitLab's role as an AI provider for the AI service GitLab Duo and its components.

Assets

Assets within the scope of the management system include: customer data, software, people, and internal information assets to host and operate the cloud-based solution.

External assets that are subject to shared responsibility include cloud service providers and artificial intelligence providers. The scope of shared responsibility considerations include: assets maintained and stored in the cloud computing environment, infrastructure assets management, processes that run on a multi-tenant virtualized environment, cloud service administration, and development and enhancement of AI models.

Excluded from Scope

As an all remote company, there are no physical office locations in the scope of the management system. Contracted third party data center services to include physical and environmental controls are not in scope and are managed by the third party service providers.

Locations

GitLab's headquarter mailing address is in scope and covers all sub organizations. Please note this is a mailing address only, there is no physical location to visit:

- GitLab Inc, 268 Bush Street 350, San Francisco, CA 94104, United States of America

Organizational Units

Business functions included in the scope of the management system include:

- Security - Chief Information Security Officer; Security Assurance; Product Security; Security Operations; Threat Management Security teams. Division structure is defined here
- Engineering - VP of Development
- Engineering - VP of Infrastructure and Quality
- Finance - VP of Information Technology
- People Operations - VP of Total Rewards and People Operations, Technology and Analytics
- Legal - VP of Legal Operations; Senior Director, Contracts and Legal Operations; Director of Legal, Privacy and Product
- Data Science - Responsible for leveraging ML and AI capabilities in the GitLab product, providing applied AI capabilities, and preventing abuse in the application.

Interested Parties

This management system governs GitLab security operations. Interested parties include:

- Customers
 - Require GitLab to operate according to this management system to protect their information
- Shareholders/owners of the business
 - Require GitLab to operate in a secure manner to maintain a sustainable business
- Team Members
 - GitLab requires Team Members to operate in a secure manner as defined by this management system. Require GitLab to operate in a secure manner to maintain services and provide continued employment

Management System Roles and Responsibilities

Role	Responsibility
ISMS & AIMS Council	Oversight, implementation and continual improvement of the management system
Chief Information Security Officer	Executive sponsor of the management system; coordinate, promote and improve information security
Security Management (Code Owners)	Owner of the management system responsible for approving significant changes and exceptions of the management system
Security Assurance	Reporting on the performance of the information security management system to top management; security risk assessments and treatment; continuous monitoring and auditing; customer assurance activities; security awareness program; security governance activities
Product Security	Manage third party penetration and bug bounty programs; provide input to

the software development lifecycle; manage application vulnerability program; administer security champions program; maintain application security tools; identify security risks; infrastructure vulnerability program; maintain infrastructure security tools; identify security risks |

| Security Operations | Monitor, manage and report on security incidents; monitor compliance with security policies through technical tools; identify security risks; monitor and respond to abuse of SaaS subscriptions |

| Corporate Security | Manage identity and access management, role based access control, admin access |

| Duo Product Management| Monitor performance of AI system; maintain AI system; identify AI risks; evaluation of the performance of AI model providers |

| Legal| Responsible for AI governance; third-party contracts; privacy reviews|

| Other management system business units | Implement, operate and/or administer information security requirements; remediate information security findings; collaborate with the Security department |

| All GitLab Team Members | Awareness of responsibilities as it relates to information security; adherence to information security controlled documents; reporting of suspected security violations |

Implementation Manual Procedure

Leadership

GitLab is committed to information security. The general objective for the ISMS is to protect GitLab's confidential information and assets against new and existing security and privacy risks while maintaining confidentiality, integrity and availability. Objectives for individual security controls are inherited by the in scope security standards and regulations which are: ISO 27001:2022, and SOC 2 Type 2.

The council, comprised of Security and Privacy (Legal) leadership, shall meet on a minimum of an annual basis to discuss the state of the management system and measure the fulfillment of all management system objectives. The following topics will be covered:

- Review of membership and objectives
- ISMS & AIMS Internal Audit Results
- Significant controlled document updates
- Results of the Annual Security Risk Assessment
- Changes to Risk Heatmap (trends)
- Output from Continuous Control Monitoring
- Observations (CA/PAs)
- Changes that could affect the management system
- Feedback and improvements
- Management system inputs and outputs

Planning

GitLab has implemented a formal Security Operational Risk Management ("StORM") program to identify, rank, track, and treat cybersecurity, IT, and privacy operational risks in support of GitLab's organization-wide objectives. Internal and external issues that could impact GitLab's ability to achieve the intended outcomes of the ISMS and AIMS are identified as part of the

StORM or Observation Management Program. The process for selecting in scope information security controls is executed by the Security Compliance team, leveraging technical functionality from the third party GRC application, and overseen by the Security Risk team. Implementation status is captured in GitLab's GRC application as well as in the Statement of Applicability.

On an annual basis, the CEO will establish company objectives for the year that cascade down to all divisions, including Security and AI teams. These objectives ensure that security and AI management priorities remain aligned with GitLab's overall strategic direction, providing a framework for defining specific actions to support the intended outcomes of both the ISMS and AIMS.

Support

GitLab has implemented a formal security awareness training program that includes: new hire security awareness training, global annual security awareness training and quarterly targeted phishing exercises. These trainings are administered through a third party portal and include a quiz to test understanding of the security topics presented.

A formal controlled document procedure is in place to ensure that there is consistency in developing and maintaining controlled documents at GitLab utilizing a hierarchical approach. All controlled documents are available to all GitLab team members and the public through the GitLab handbook unless otherwise noted. Updates to controlled documents are managed via GitLab merge requests which are also accessible to all GitLab team members for the entire workflow. An annual review of controlled documents is required by the owner or assigned representative.

GitLab publishes Job Families to define roles and responsibilities based on level for all team members. This information is publicly available and the foundation for team member hiring and performance reviews. On a minimum of an annual basis, GitLab management executes talent assessments with team members to ensure competency to Job Family.

Operations

The GitLab team handbook is the central repository for how we run the company. Everything at GitLab is handbook first, to include development of company policies, standards and procedures. Key controlled documents that support the management system include:

- Data Classification Standard
- Internal Acceptable Use Policy
- Security Policies
- GitLab Code of Business Conduct and Ethics
- Infrastructure Change Management Procedure
- Security Operational Risk Management (StORM) Program & Procedures
- GitLab AI Ethics Principles for Product Development
- General Purpose AI Tool Usage Guidelines
- Approved AI Tools

GitLab has a dedicated Security Compliance team responsible for monitoring design and effectiveness of the GitLab common control framework to ensure GitLab's security objectives are thoughtfully planned, implemented and monitored.

If using a third-party service to outsource or supplement security processes, a third party risk assessment is executed prior to onboarding. Critical vendors are also reviewed once per calendar year after onboarding, or at contract renewal if it comes first.

Performance

GitLab monitors, measures, and improves security controls through various continuous monitoring measures, such as:

- Continuous control testing/Annual management system internal compliance audits
- External audits (SOC 2 Type 2, TISAX, customer security assessments)
- Annual security operational risk assessments
- Annual third-party penetration testing
- Ongoing third party scorecard monitoring (BitSight)
- Infrastructure Vulnerability scanning
- Application Vulnerability Scanning
- HackerOne bug bounty program
- Audit log monitoring
- ISMS & AIMS Council (annual management review)

Improvement

GitLab is committed to continually improving the suitability, adequacy and effectiveness of the management system.

As part of GitLab's tier 2 security operational risk program, each risk identified and triaged through the StORM program is required to undergo a risk response decision. This is an activity that will be discussed with each individual risk owner for the risks that they own.

Additionally, GitLab identifies and monitors tier 3 risks, also referred to as observations, as per the Observation Management Procedure.

Exceptions

Exceptions to Information Security policies or procedures will be tracked as per the Information Security Policy Exception Management Process.

References

- Controlled Document Procedure

SECTION: security/learning-and-development.md

Overview

This page is created as a result of the FY21Q4 Culture Amp survey, where Security team members expressed a desire to improve on the currently available L&D opportunities at GitLab. In order to paint a holistic picture of L&D resources available to team members, some of the resources detailed on this page are not Security-specific and are already documented in the handbook.

L&D resources available to all team members

GitLab provides a multitude of opportunities to learn and develop new skills on the topics of leadership, management, and DIB. Level Up is the platform of choice that allows self-paced, on-demand courses. If you're looking for a more flexible approach to learning the aforementioned skills, then perhaps the learning initiatives provided by the L&D team are something for you to consider.

Growth and Development Fund

Within the Growth and Development benefit, GitLab allows team members to spend \$10,000 on Growth and Development annually. The individual Growth and Development budget can be used to attend conferences and workshops, obtain certifications, professional coaching, academic study and more. The extensive list of Growth and Development types of reimbursement can be found on [this page](#).

Learning and development within GitLab Security

Professional Trainings

The ability to pursue professional trainings is of critical importance to security professionals due to the fast and ever-changing security landscape. Team members are encouraged to identify training courses, certifications, and conferences that of interest that are related to their roles and responsibilities. If seen as relevant, these resources are going to be added to the team member's Individual Development Plan (IDP). Trainings are a great way to empower team members to gain new knowledge and approaches to situations they face in their roles. Trainings are a great tool to improve productivity and efficiency at work, but they must not be seen as a goal in itself - while knowledge gained from trainings can positively impact your career growth, if applied, the trainings alone bear no weight the likelihood of your progressing your career.

Some great security trainings are available at the following providers:

- SANS
- Offensive Security
- PluralSight
- Udemy

Dedicate time to L&D

As a Security team member, you have the opportunity to dedicate 8 working hours per month to L&D. This does not account for multi-day trainings.

It is recognized that there is a trade off with this initiative using the fundamental concepts of a cut-off line and one-in, one-out philosophy. In order to prioritize this time the opportunity cost should be clearly identified and impact assessed. Therefore, team members who decide to make use of this initiative will need to discuss the ideas with their direct manager. The 8 hours are to be used on an agreed upon schedule. The schedule can be 1 day per month, 4 hours twice per month, 2 hours weekly, and so forth. This is also to ensure that the effort is used towards career objectives and professional growth. As such, dedicated L&D time

should be captured in participating team member's IDP.

Leadership shadowing

We currently have the Security Shadow program available to all team members. In addition to that we're also working on a Security Leadership shadowing idea, which would be based around the CEO Shadow model. We'll update this entry as we make progress on it.

Share what you have learned with other team members

A big part of an informal learning process is leaning on what your peers are doing and what they have accomplished. As such, it is very important to take the time to document what you have learned from official trainings that you've attended, provide any materials that you're allowed to, and present any major developments in the monthly Show & Tell meeting.

Security knowledge base

You'll be expected to provide a summary, key take-aways, and any supporting materials to other Security team members whenever you complete a training that GitLab pays for. To do this, make use of the dedicated Security Knowledge Base group:

- Create a new project and name it accordingly
- Provide a markup formatted write-up in the form of a README.md in the project, documenting as much you can, but at least the following:
 - Name of the training
 - Date of the training
 - URLs to the training
 - Description of the training
 - Personal impression
- Upload as much supporting material to the project as you're allowed to by the authors of the training

Show & Tell

The Security Department Show & Tell takes place every 2nd Thursday, changing times each time to ensure both APAC and EMEA team members are able to attend at least once a month. Everyone at GitLab is welcome to join the Show & Tell and it's actively advertised in security-division.

The purpose of the Show & Tell is to encourage the sharing of knowledge with your Security peers and other team members - anything from proof-of-concepts, demos, ideas, books, trainings will do.

SECTION: security/maturity-models.md

Overview

Our maturity models track specific states and behaviors of our teams over time. This gives us a roadmap to deliver better outcomes with increased efficiency.

Process

Following our sub-values of dogfooding and adopting boring solutions, the process to create and maintain our maturity models is based on GitLab features only.

Each team of the Security Division should maintain their own maturity models.

Tooling

Maturity models leverage Issue Boards to organise and track progress on the various processes. These issue boards are located in projects under the team GitLab group in <https://gitlab.com/gitlab-com/gl-security/> (for example: <https://gitlab.com/gitlab-com/gl-security/security-operations/redteam/redteam-internal/red-team-maturity-model/> for the Red Team).

Each process of the maturity model is presented by an issue with a short title and a longer description.

Issue labels are used to define the current level and state of the process.

Labels

Maturity levels

The ~Maturity Level:: label reflects the level of the process and is mandatory. There are five levels defined along the continuum of the model (see the "Capability Maturity Model" wikipedia page for more details):

- ~Maturity Level::Initial (1)
- ~Maturity Level::Repeatable (2)
- ~Maturity Level::Defined (3)
- ~Maturity Level::Capable (4)
- ~Maturity Level::Efficient (5)

These labels must use the color 6699cc (blue) for consistency.

Progress labels

The ~Maturity:: label reflects the current state of the process and is optional when activity hasn't started yet:

- ~Maturity::In Progress: The team is actively working to achieve this state or behavior. Color: 6699cc (blue)
- ~Maturity::Replaced: This state or behavior was previously achieved, but has since been replaced in later maturity level. Color: 8fbc8f (green)
- ~Maturity::Established: This state or behavior has been achieved, and is still being improved and applied. Color: 009966 (dark green)

Resources

- "Capability Maturity Model" wikipedia page

SECTION: security/network-isolation.md

Why

There are various reasons why you might want to isolate your work notebook from other devices in your home network:

- Security concerns. The security of individual devices on your home network might vary. Some are notoriously insecure (e.g. smart home devices) or some might simply lack the latest security patches. Isolating devices with poor security from your work notebook (and other sensitive private devices) can increase the security of your work notebook.
- Privacy concerns. GitLab is an all-remote company, with many of its employees working from home. As a side-effect, our work notebooks typically end up being connected to the same network as our personal devices, which allows for network access between these two groups of devices and may raise privacy concerns.

How

Many home routers allow connected devices to be isolated, which prevents any direct network communication between selected devices. This section walks you through setting up an isolated WiFi specifically for your work notebook. The goals specifically are:

- Prevent direct connections to and from your work notebook towards other devices in your home network.
- Prevent your work notebook from accessing your router's management interface.
- Have internet access with your work notebook (of course :smile:)

Note that devices connected via different bands (2.4GHz and 5GHz) are typically not isolated from each other. Likewise, devices connected to your router via cable are not separated from devices connected via WiFi.

Simple Isolation with Guest Network

Many modern WiFi routers have the capability to generate bridged guest networks that separate devices on the network from each other while keeping things easy to understand. Rather than using your router's built in guest network support for guests, you can instead use it for your work devices. This effectively works the same way as having untrusted guests connecting to your network and should isolate your work device from other devices connected to your home network.

While most routers implement guest networks as described, be aware that your router might implement guest networks differently. Check your router's manual for details.

Note that you will likely not be able to connect to shared resources in your home network such as file servers or shared printers.

Simple Isolation with Personal VPN

A personal VPN (Virtual Private Network) can create an isolated network for a team member's computer that could be used for isolation if the Guest Network idea does not meet your needs. This has the added advantage of being mobile, in that if you take your computer to any network (free Wi-Fi at a coffee shop, hotel network, technical conference with Wi-Fi access for attendees, etc) you can isolate it.

For more information on a personal VPN, check out the [Personal VPN](#) page.

Similar to the guest network scenario above, when using a personal VPN you will not be able to access shared resources in your home like a printer.

Advanced Isolation with DDWRT

The instructions are specific to DDWRT, which is a popular custom router firmware. If you don't use DDWRT, you can use the provided steps as a template and consult your router's manual to obtain a similar configuration. However, if your home router does not support setting up an isolated network, consider buying a router that is compatible with DDWRT (ToDo: check which ones support Net Isolation) or a similar custom firmware. If you need recommendations for DDWRT routers, you can find many buyer guides online:

- [ProPrivacy](#) guide
- [List of supported DDWRT devices](#)

1. Backup config. Before you start setting up your new work WiFi, you should save your current configuration so that you can restore it if necessary. To do this, go to tab Administration -> Backup.

1. Create your work WiFi. On tab Wireless -> Basic Settings, go to section Virtual Interface and click the Add Virtual AP button. Choose a name for your work WiFi and enter it in Wireless Network Name (SSID).

1. Advanced WiFi configuration. Tick Advanced Settings to open up more configuration opens for our newly created WiFi. Set Network Configuration to Unbridged. Enable Masquerade / NAT and Net Isolation (this option creates a couple of firewall rules that blocks your work notebook from reaching your private network and vice versa). Assign an IP address, e.g. 172.16.2.1, and set the subnet mask accordingly, e.g. 255.255.255.0. Hit Save at the bottom of the page.

1. Setup Security. Next, we will set up encryption. Go to tab Wireless Security and go to the section that shows the name (SSID) of our newly created WiFi. Tick WPA2 Personal, CCMP-128 (AES) and enter the WiFi password into WPA Shared Key. Hit Save.

1. Set up DHCP. To automatically assign an IP address to devices on our new WiFi, we have to enable DHCP. Go to tab Setup -> Networking, scroll to section DHCPD at the bottom. Click Add and select the interface belonging to our new WiFi (most likely ath0.1) and hit Save.

That's it. If you search for nearby WiFi on your work notebook, our new WiFi should show up with the name you assigned.

Above steps are adapted from an existing guide.

SECTION: security/okr.md

Security OKRs

The Security organization executes quarterly Objectives and Key Results or OKRs.

How We Plan, Assign, and Execute Work

Four Mondays before the start of the fiscal quarter, in the days after the CEO shares OKRs with all of GitLab in the okr channel, the CISO proposes OKRs for the Security Division in the OKR draft review meeting agenda for a maximum of 5 objectives. Security leaders are to propose draft OKRs to the CISO prior to the meeting for inclusion.

From FY24 Q1 forward all Security OKRs are documented in the GitLab OKR project. For easy filtering, all Security Objective and KR issues have the division::Security label applied.

Larger initiatives that span the scope of multiple teams or projects may require a Working Group.

{{% alert title="Note" color="primary" %}}

Critical Projects occur somewhat regularly and take priority over OKRs.

{{% /alert %}}

Alignment to CEO OKRs

The security division exists to enable the business to iterate on its OKRs. This means that Security OKRs won't generally have a direct relationship to CEO-level OKRs but are nonetheless foundational for the business to have continued success.

Within the context of OKRs, what is a priority?

A prioritized OKR objective directly contributes to the elimination, mitigation, or transference of a Top-5 risk and is generally aligned with our multi-year strategy (internal link). As such, each security sub-department may not issue their own OKRs in a given quarter. For example, Security Assurance output results in the creation of our Top 5 risks and the execution of compliance activities. As such, a focus on business as usual may be prioritized.

Given an agreed-upon priority, how do functional areas align?

Before the new quarter:

- Seven Mondays prior: Boilerplate Google Doc with rough ideas is created and shared across functional leaders
- Six Mondays prior: Functional leaders collaborate (async and sync) and determine objectives for the coming quarter. Each functional leader is responsible for proposing at least one objective or contributing to an already-proposed objective inclusive of up to 3 KRs per objective. Security functional leaders are to propose draft OKRs to the CISO.
 - KRs at this level should have clear, data-driven, quantitative targets. In some cases it's okay for KR to be centered around establishing a baseline KPI.
- Four Mondays prior: In the days after the CEO shares OKRs with all of GitLab in the okr channel, the CISO proposes OKRs for the Security Division in the OKR draft review meeting

agenda for a maximum of 5 objectives.

- Senior Managers and above within security participate in a draft review to fully identify dependencies on teams in other functional areas and to gain any needed KR clarification from senior leadership.
 - Two to four Mondays prior: Managers in functional areas work with their teams to prepare KR work for the coming quarter. As described in the handbook, new dependencies may be discovered and should be triaged accordingly. A team that is a dependency on another team's KR is responsible for confirming the ability to support that work with the accountable team. This is determined between directly impacted managers. The KR is not considered finalized until that confirmation happens. In the event of a team's inability to support, the KR is re scoped or removed; the overarching objective should only be reworked in circumstances where the at-risk KR is responsible for over 50% of the success criteria for that objective.
- "No capacity" decisions should be documented as a leadership metric, primarily for future capacity and headcount planning purposes.
- Two Mondays prior: OKRs are finalized and shared in the GitLab OKR project.

Labels

Labels are applied to our OKRs and KRs to ease grouping and search, but also to reflect their priority.

Apply:

- The ~Division: Security label to both OKRs and KRs
- The FY<yy>-Q<x> label to both OKRs and KRs
- The ~OKR label to OKRs only
- The ~sec-okr::p<x> priority label (see below) to OKRs only

Priority label

We use the following labels to reflect the priority of our OKRs:

The Priority scoped label ranges from 0 to 2 and is applied to OKRs.

- sec-okr::p0: Should only be reserved for Critical Projects
- sec-okr::p1: 70% or greater completed across the team/Objective, important
- sec-okr::p2: Stretch (future P1 or P0, if we knock out P0/1 we will hit these)

What does it mean to be a DRI for a KR?

A KR Directly Responsible Individual (DRI) is meant to be the person accountable for the success of that key result.

This doesn't mean you are the assignee for each individual milestone in the KR, but rather that you're the person driving change forward to ensure the KR is successful and the progress, risk, and blockers are appropriately communicated within the Security Assurance team.

Being a DRI for a KR includes:

- Drafting KR milestones (including consistent titling)

- Monitoring weekly status of milestone progress
- Proactively alerting the appropriate stakeholders if a milestone is at risk of on-time completion
- Weekly KR reporting to support OKR-level leadership updates

A given objective is DRI'd by a functional leader (ProdSec, SecOps, SecAssurance, etc) or a direct report of a functional leader. If it seems an individual contributor could own an objective, then the objective is probably too narrowly scoped.

A given KR is DRI'd by a manager or IC. The rule is that the DRI should be able to impact the KR directly through their individual actions

The DRI for the KR does not need to be a part of the department that owns the Objective. For instance, an InfraSec IC can DRI for a KR under a SecOps objective.

Templates

New Security KR - GitLab Template

:scissors: Copy and paste the below into the GitLab Issue Description

text

Issue Title: FYxx-Qx KR (OKR Title Reference) measurable title. Example: FY22 Q3 KR1 (Security Training) Achieve 90% completion rate org wide for annual security training.

Dependencies

what do you need to be successful with this KR

Milestones

- [] Milestone 1: Description: add here DRI: add here
- [] Milestone 2: Description: add here DRI: add here
- etc.

Security KR Weekly Update

Field updates:

- Progress %
- Health Status: On Track/Needs Attention/At Risk

:scissors: Copy and paste the below into the GitLab.com KR Issue(s) at the end of the week

text

Weekly KR Update for the week starting on YYYY-MM-DD

What was accomplished this week

-

What will be accomplished next week

-

With YYYY-MM-DD being the beginning of the week (Monday, even if this day is a holiday or a Family and Friends day).

Cross-organizational collaboration and sharing

What do other teams typically hope to gain with insight into our strategic objectives? This is the lens we should use for defining this work. Understanding the strategic initiatives of a sister division is important for purposes of anticipation and calibration of expectations.

How do we share this, most simply, with other teams?

This presents a minimally viable model. If our sister organizations end up needing something differently, we can iterate.

- What we are working on "right now" Well-architected Labels and supporting links to epics/etc
- What are your overarching strategic priorities? CISO's multiyear + functional strategy documents (example: Multi-year ProdSec Strategy)
- What is the security org focused on this year? A bullet list of general priorities for the year:
 - Each functional leader provides 1-3 bullets, 1-2 sentences each to the bullet list.
 - These should rarely change, but pragmatism should always win.

SECTION: security/password-guidelines.md

<!-- markdownlint-disable MD051 -->

Passwords at GitLab

Passwords are one of the primary mechanisms that protect GitLab information systems and other resources from unauthorized use. GitLab's password standard is based, in part, on the recommendations by NIST 800-63B.

The password standard sets the requirements for constructing secure passwords and ensuring proper password management. GitLab utilizes 1Password for password management.

1Password

1Password is a password manager that can be used in two different ways - as a standalone application (by purchasing a standalone license) or as a hosted service (by subscribing). GitLab uses 1Password for Business which is a hosted service.

Important: Any personal Passwords stored in your GitLab vault will be inaccessible upon separation with GitLab. Please use the complimentary 1Password Families membership subscription that comes with your business account to store any personal passwords. This

account will stay with you even in the event that you stop working with GitLab.

For more information on how to redeem your free subscription, please follow the steps outlined in this article.

Ideally you memorize one strong password - hence the name - and let 1Password generate and manage strong, unique passwords for every site for which you have a login.

GitLab requires all team members to use Okta as a primary entry and access point for SaaS and other company applications while utilizing 1Password for password management. GitLab utilizes Okta for SAML/SSO and passwordless authentication for many applications, so the need to store passwords in a password manager will diminish over time.

If you want to use 1Password for your private passwords not related to your work at GitLab, there are a few options.

Please note our 1Password for Business license agreement includes the 1Password for Families feature, which you can share with up to 5 family members.

For your Okta password and other passwords that you won't store in Okta, use 1Password as your password manager and set a strong and unique master password.

- Keep your Master Password a secret. No other team members should know it, including admins. If the Master Password is known or disclosed to someone else, it should be changed immediately.
- Post a message in [ithelp](#) if you forget your Master Password.
- Consider using a generated Master Password. Most human-created passwords are easy to guess. Let 1Password create a strong Master Password. But: you will need to memorize this Master Password.
- Do not let your password manager store the master password. It is okay to store the username.
- For more information, review 1Password's [Getting Started](#) guide and view this [video](#) that guides you through the sign-up process.
- For account administrators, review 1Password's [admin guide](#).

Terminology

Following this guide, it will be helpful to understand a few terms we'll be using throughout.

- App: A native 1Password application (macOS, iOS, Windows, Android).
- Extension: A web browser extension/plugin that communicates with the App to provide access to your passwords securely without leaving the browser.
- Vault: What 1Password calls any grouping of secure data, such as logins or secure notes. Sometimes called a "keychain".

1Password guidelines

1. If you install the macOS application, install 1Password via this [link](#)

1Password

1. If you have a YubiKey, it can be added as a 2-factor method to your 1Password account for convenience.
1. When traveling, consider using 1Password in "Travel Mode", see more on that below.
1. Do not share credentials via email, issue comments, chat etc. This includes email addresses to login and API keys. Use 1Password vaults for this and if sharing a one-off password, the built-in "Share" feature.
1. If you do not have access to a vault create an access request issue.
1. Use Watchtower to find passwords that need to be changed. Watchtower tells users about password breaches and other security problems on the websites they have saved in 1Password Teams, so users can take action. This is not something account administrators can review for team members, so it is up to you to enable! Enable Watchtower by